

Fortigap Cybersecurity Assessment Questions

Instructions: Provide responses for multiple-choice, 0–5 maturity ratings, and open-ended fields. If Not Applicable (N/A), indicate so.

Section 1: Company & Assessment Information (Strategic Context)

1. Company Description

- [Your Answer]

2. Industry Sector (choose one)- ignore this one

- ☐ Healthcare & Life Sciences
- ☐ Financial Services & Banking
- ☐ Technology & Software
- ☐ Manufacturing & Industrial
- ☐ Retail & E-commerce
- ☐ Education & Research
- ☐ Government & Public Sector
- ☐ Energy & Utilities
- ☐ Legal & Professional Services
- ☐ Other

3. Company Size (choose one)

- ☐ Small (1-50)
- ☐ Medium (51-500)
- ☐ Large (501-2,000)
- ☐ Enterprise (2,000+)

4. Applicable US Privacy Laws (select all)

- [] CCPA/CPRA
- [] VCDPA
- [] CPA
- [] UCPA
- [] CTDPA
- [] NY SHIELD
- [] BIPA
- [] ICDPA
- [] INCDDPA
- [] TIPA
- [] MCDPA
- [] DPDPA
- [] NJCDPA

5. Strategic Context & Objectives

- [Your Answer]

6. Previous Security Assessments & Outstanding Issues

- [Your Answer]

7. Current Top Security Concerns & Threat Landscape

- [Your Answer]

8. Business-Critical Systems & Data at Risk

- [Your Answer]

9. CISO Perspective & Leadership Context

- [Your Answer]

10. Compliance Management & Evidence Collection

- [Your Answer]

Section 2: Operational Security Practices

Endpoint & Device Management

1) Local Admin Privileges (choose one)

- ☐ 0–10%

- ☐ 11–30%

- ☐ 31–60%

- ☐ 61–90%

- ☐ 91–100%

2) Software Installation Method (choose one)

- ☐ Centrally managed

- ☐ IT approval/manual install

- ☐ User download + IT approval

- ☐ User download freely (local admin)

3) Patch Management Cadence (choose one)

- ☐ Continuously/Weekly

- ☐ Monthly

- ☐ Quarterly

- ☐ Ad-hoc

4) EDR Coverage (choose one)

- ☐ 0%

- ☐ 1–25%
- ☐ 26–75%
- ☐ 76–100%

BYOD & Remote Access

1) BYOD Policy & Controls (choose one)

- ☐ Not permitted
- ☐ Comprehensive controls (MDM, etc.)
- ☐ Limited/inconsistent controls
- ☐ No policy/controls

2) Remote Access Method (choose one)

- ☐ ZTNA
- ☐ VPN + MFA
- ☐ Basic VPN (no MFA)
- ☐ Direct internet access

3) MDM/UEM Coverage (choose one)

- ☐ 76–100%
- ☐ 26–75%
- ☐ 1–25%
- ☐ 0%

Shadow IT & Cloud Services

1) Unsanctioned App Management (choose one)

- ☐ Comprehensive monitoring (CASB)

- ☐ Basic monitoring (logs/manual)
- ☐ Reactive only
- ☐ No process

2) Personal Cloud Storage Policy/Enforcement (choose one)

- ☐ Technical DLP monitoring/prevent
- ☐ Technical blocking to personal cloud
- ☐ Policy only (no enforcement)
- ☐ No policy

Network & Data Governance

1) Network Access Control (choose one)

- ☐ NAC (authN/Z + posture + segmentation)
- ☐ Credentials + basic registration
- ☐ Basic/shared authentication
- ☐ Open access

2) Data Classification System (choose one)

- ☐ Enforced with technical controls
- ☐ Defined but inconsistent/manual
- ☐ General understanding, no formal system
- ☐ No formal system

3) Offboarding Data Management (choose one)

- ☐ Automated workflows (IdP + MDM)
- ☐ Standardized checklist + remote wipe
- ☐ Manual checklist; personal devices not enforced

- ☐ No process

Advanced Security Controls

1) Centralized Logging/SIEM (choose one)

- ☐ SIEM real-time
- ☐ Basic collection/analysis
- ☐ Manual/reactive review only
- ☐ No central logging

2) Vulnerability Scanning Frequency (choose one)

- ☐ Monthly or more
- ☐ Quarterly/Semi-annual
- ☐ Annually or less
- ☐ Never/on request

3) Endpoint DLP (choose one)

- ☐ Comprehensive DLP
- ☐ Basic DLP (USB/web blocks)
- ☐ Policies only
- ☐ No DLP

4) Security Baseline Enforcement (choose one)

- ☐ Automated enforcement/monitoring
- ☐ Defined + periodic audits
- ☐ Defined but manual/inconsistent
- ☐ No baselines

Section 3: Security Maturity Assessment (0–5 with details, N/A if applicable)

For each domain:

- Rating (0–5):

- If Not Applicable:

- Your Specific Details: [type specific tools and processes]

1) Identity (IAM, SSO, MFA, JML)

Levels 0–5: Ad-hoc → Basic IAM → MFA/SSO → RBAC/JML → PAM → Zero Trust

2) Asset Management (Inventory, ownership, classification)

Levels 0–5: None → Manual → Discovery → CMDB → Ownership/Classify → Lifecycle

3) Infrastructure Security (Endpoints, firewalls, networks)

Levels 0–5: None → Basic → Hardening/Patching → Segmentation → EDR/NGFW → Micro-seg

4) Application Security (SDLC, scanning, dependencies)

Levels 0–5: None → Occasional testing → Dev training → SAST/DAST → SCA → Threat Modeling

5) Supply Chain Risk (Vendor security)

Levels 0–5: None → Basic questionnaires → Risk-based → Contract reqs → Continuous monitoring → Deep integration/SBOM

6) Incident Response

Levels 0–5: None → Basic plan → Documented/Tested → Roles/Playbooks → SOAR → DR tested (RTO/RPO)

7) Governance & Risk

Levels 0–5: None → Basic policies → Library → Risk register → GRC tooling → Exec oversight

8) Data Protection (Encryption, backups, retention)

Levels 0–5: None → Transit → At-rest → Classification → DLP/Backups → Key management

9) Security Training

Levels 0–5: None → Annual → Phishing sims → Role-based → Champions → Culture

10) Cloud Security

Levels 0–5: None → Basic IAM → CSPM → Least privilege → CWPP → Auto remediation

11) Business Continuity

Levels 0–5: None → Backups only → Doc plans → Tested plans → RTO/RPO → Integrated crisis mgmt.

Section 4: NIS2 Directive Alignment (if applicable)

1) Supply Chain & Third-Party Security

- [Your Answer]

2) Business Continuity & Crisis Management

- [Your Answer]

3) Vulnerability Handling & Disclosure

- [Your Answer]

4) Use of Cryptography & Encryption

- [Your Answer]

5) Essential/Important Services Identification

- [Your Answer]

6) Cybersecurity Governance Framework

- [Your Answer]

7) Human Resources Security & Training

- [Your Answer]